

NIST RISK MANAGEMENT FRAMEWORK

AND SP 800-53 RELEASE 5.2.0

Practical Manager and Junior Analyst Manual

What this manual does: Explains the seven RMF steps, all 20 SP 800-53 control families, baselines, tailoring, implementation, assessment, authorization, monitoring, OSCAL, open-source tools, management decisions, and job-ready analyst work.

Alberto (Al) Leiva

First Edition • July 2026

Preface

The Risk Management Framework is a disciplined way to connect mission needs, system design, security, privacy, evidence, and accountable risk decisions throughout a system life cycle. SP 800-53 is the control catalog used within that process; it is not a checklist that automatically creates security or an authorization.

This manual uses plain language, realistic workpapers, and safe labs. Federal terms are explained, but nonfederal organizations can adapt the concepts. Requirements and authority vary by law, agency, contract, sector, system, and risk. Use current official sources and qualified security, privacy, engineering, legal, acquisition, audit, and authorizing professionals for real decisions.

Current-information note: Verified July 14, 2026: SP 800-37 Rev. 2 remains the current final RMF; SP 800-53 and SP 800-53A are at Release 5.2.0 (August 2025); SP 800-53B baselines were reissued without baseline changes; SP 800-18 Rev. 2 was finalized June 30, 2026.

How to use this manual

- Managers: begin with Chapters 1–4, 7–13, 17–18, and 27.
- Junior analysts: study in order, practice Chapters 26 and 28–29, and use the templates.
- System owners and engineers: focus on boundary, selection, implementation, evidence, monitoring, and family chapters.
- Assessors: focus on Chapters 10, 15–18, 25, and 30.
- Tailor every artifact to the organization’s authority, risk tolerance, system, and obligations.

Table of Contents

This document contains a native Word table of contents and a permanent chapter guide.

Preface	2
How to use this manual.....	2
Table of Contents	3
Chapter Guide	7
1. RMF and SP 800-53 Foundations	8
2. Current NIST Publication Suite	9
3. Governance, Roles, and Risk Decisions	10
4. System Life Cycle, Scope, and Authorization Boundary	11
4.1 Boundary questions	11
5. Prepare at the Organization Level	12
5.1 Organization preparation	12
6. Prepare at the System Level	13
6.1 System preparation	13
7. Categorize the System	14
7.1 Method	14
8. Select Controls.....	15
8.1 Selection sequence.....	15
9. Implement Controls.....	16
9.1 Implementation workflow	16
10. Assess Controls.....	17
10.1 Assessment sequence	17
11. Authorize the System or Common Controls.....	18
11.1 Authorization package	18
12. Monitor Continuously	19
12.1 Monitoring activities	19
13. Control Baselines and Tailoring	20
13.1 Tailoring record	20
14. Common, Hybrid, and System-Specific Controls.....	21
14.1 Inheritance checks	21
15. Writing Strong Implementation Statements.....	22
15.1 Statement checklist	22

16. Assessment Planning and Evidence.....	23
16.1 Population and sampling	23
17. Authorization Package and POA&M	24
17.1 POA&M quality	24
18. Continuous Monitoring Strategy	25
19. OSCAL and Automation	26
19.1 Automation safeguards	26
20. Control Families: Access, Awareness, Audit, and Assessment.....	27
AC — Access Control.....	27
AT — Awareness and Training.....	27
AU — Audit and Accountability	27
CA — Assessment, Authorization, and Monitoring	27
21. Control Families: Configuration, Contingency, Identity, Incident, and Maintenance	28
CM — Configuration Management	28
CP — Contingency Planning	28
IA — Identification and Authentication	28
IR — Incident Response	28
MA — Maintenance.....	28
22. Control Families: Media, Physical, Planning, Program, and Personnel	30
MP — Media Protection	30
PE — Physical and Environmental Protection	30
PL — Planning	30
PM — Program Management	30
PS — Personnel Security	30
23. Control Families: Privacy, Risk, Acquisition, Communications, Integrity, and Supply Chain.....	32
PT — PII Processing and Transparency.....	32
RA — Risk Assessment.....	32
SA — System and Services Acquisition	32
SC — System and Communications Protection	32
SI — System and Information Integrity	32
SR — Supply Chain Risk Management.....	33
24. Privacy Risk and Security–Privacy Collaboration.....	34
24.1 Collaboration	34
25. Software Updates, Patch Reliability, and Release 5.2.0	35

25.1 Evidence focus	35
26. Open-Source Tools and Official Resources	36
26.1 NIST CPRT.....	36
26.2 NIST OSCAL Content	36
26.3 Compliance Trestle	37
26.4 Lula	37
26.5 CISO Assistant	37
26.6 Heimdall.....	37
26.7 OpenControl.....	37
26.8 OSCAL CLI	38
26.9 Wazuh	38
26.10 OpenSCAP	38
26.11 osquery.....	38
26.12 Nmap.....	38
26.13 Greenbone Community Edition	39
26.14 Trivy	39
26.15 OWASP ZAP	39
26.16 Keycloak	39
26.17 DefectDojo.....	40
26.18 Open Policy Agent	40
27. Manager's RMF Playbook	41
27.1 Manager rhythm	41
28. Junior Analyst Career Guide	42
28.1 Common roles	42
28.2 Typical work.....	42
29. Fictional Laboratory, Thirty-Day Plan, and Interview Preparation	44
29.1 Portfolio lab	44
29.2 Thirty-day plan	44
29.3 What is RMF?	44
29.4 Is SP 800-53 a checklist?	45
29.5 What is a baseline?	45
29.6 What is tailoring?.....	45
29.7 What is control inheritance?	45
29.8 How do you assess a control?	45

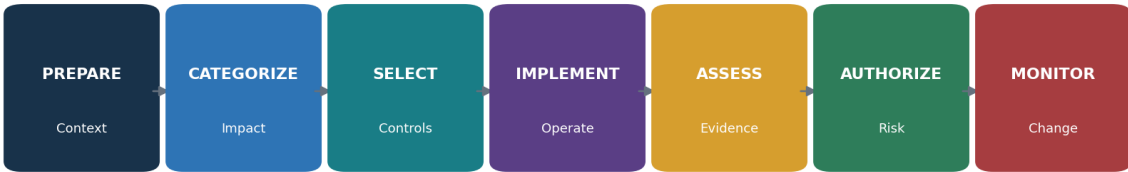
29.9 What is authorization?	45
29.10 What is a POA&M?	45
29.11 What is OSCAL?	45
29.12 What is current SP 800-53?	45
30. Templates, Glossary, Index, and References	46
30.1 System and boundary record	46
30.2 Control implementation workpaper.....	46
30.3 Assessment and finding record	46
30.4 Authorization and monitoring record	46
30.5 Glossary	47
30.6 Subject index	47
30.7 Official references.....	47

Chapter Guide

Chapter	Title	Starts on page
1	RMF and SP 800-53 Foundations	5
2	Current NIST Publication Suite	6
3	Governance, Roles, and Risk Decisions	7
4	System Life Cycle, Scope, and Authorization Boundary	8
5	Prepare at the Organization Level	9
6	Prepare at the System Level	10
7	Categorize the System	11
8	Select Controls	12
9	Implement Controls	13
10	Assess Controls	14
11	Authorize the System or Common Controls	15
12	Monitor Continuously	17
13	Control Baselines and Tailoring	18
14	Common, Hybrid, and System-Specific Controls	19
15	Writing Strong Implementation Statements	20
16	Assessment Planning and Evidence	21
17	Authorization Package and POA&M	22
18	Continuous Monitoring Strategy	23
19	OSCAL and Automation	24
20	Control Families: Access, Awareness, Audit, and Assessment	25
21	Control Families: Configuration, Contingency, Identity, Incident, and Maintenance	27
22	Control Families: Media, Physical, Planning, Program, and Personnel	29
23	Control Families: Privacy, Risk, Acquisition, Communications, Integrity, and Supply Chain	31
24	Privacy Risk and Security–Privacy Collaboration	33
25	Software Updates, Patch Reliability, and Release 5.2.0	34
26	Open-Source Tools and Official Resources	35
27	Manager’s RMF Playbook	40
28	Junior Analyst Career Guide	41
29	Fictional Laboratory, Thirty-Day Plan, and Interview Preparation	43
30	Templates, Glossary, Index, and References	46

1. RMF and SP 800-53 Foundations

RMF manages security and privacy risk through accountable life-cycle decisions.



The seven RMF steps repeat throughout the system life cycle

Figure 1. Seven RMF steps

Item	Purpose	Not the same as
RMF	Process for organization and system risk management	A control catalog or certification
SP 800-53	Flexible security and privacy control catalog	A universal checklist or baseline
SP 800-53B	Federal low, moderate, high, and privacy baselines plus tailoring guidance	A final tailored control set
SP 800-53A	Assessment methodology and procedures	Automatic proof of effectiveness
Authorization	Senior official's risk decision based on an evidence package	Statement that no risk remains
Continuous monitoring	Ongoing awareness of controls, change, and risk	A dashboard without decision action

Core idea: Controls reduce risk only when they are correctly selected, implemented, operated, assessed, corrected, and monitored in the real system context.

2. Current NIST Publication Suite

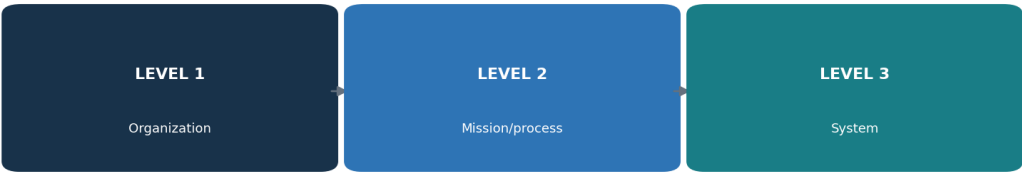
Use the current official source and understand how each publication supports the whole.

Publication/resource	Current use
SP 800-37 Rev. 2	Seven-step RMF tasks, roles, organization/system preparation, and life-cycle risk management
SP 800-53 Release 5.2.0	Current security and privacy control catalog, including 2025 software update and patch changes
SP 800-53A Release 5.2.0	Current assessment procedures corresponding to Release 5.2.0
SP 800-53B Release 5.2.0	Federal low/moderate/high and privacy baselines; 2025 reissue made no baseline changes
SP 800-18 Rev. 2	June 2026 system security, privacy, and C-SCRM plan elements; machine-readable emphasis
SP 800-30 Rev. 1	Risk assessment guidance
SP 800-39	Organization-wide risk management at three levels
CPRT	Browser and downloads for current controls, baselines, procedures, and references
OSCAL	Machine-readable models for catalogs, profiles, components, SSPs, assessments, and POA&Ms

Version control: Record the source publication, release, format, retrieval date, profile/baseline version, and local tailoring. Never mix control text, procedures, and baselines from different releases without analysis.

3. Governance, Roles, and Risk Decisions

RMF roles separate implementation, assessment, ownership, and risk acceptance.



Risk decisions and controls connect enterprise direction to system operation

Figure 2. Three risk-management levels

Role	Primary responsibility
Head of agency / organization	Organization-wide accountability and risk governance
Risk executive (function)	Consistent risk perspective and portfolio-level coordination
Authorizing official	Accepts system/common-control risk or imposes conditions/denies authorization
Authorization official designated representative	Coordinates activities as delegated; does not inherit ungranted risk authority
System owner	System mission, resources, plans, controls, package, and operation
Information owner / steward	Information requirements, impact, use, sharing, and protection
Security / privacy officers	Program requirements, advice, oversight, and coordination
Control provider	Implements and documents common, hybrid, or system-specific controls
Control assessor	Plans and performs objective assessment; reports results and limits
System administrator / engineer	Builds, configures, operates, monitors, and corrects system capabilities
Enterprise architect / mission owner	Aligns systems, processes, dependencies, and organization architecture

4. System Life Cycle, Scope, and Authorization Boundary

A clear boundary is the foundation for categorization, controls, assessment, and authorization.

4.1 Boundary questions

- What mission or business function does the system support?
- Which people, processes, applications, services, devices, networks, data, interfaces, locations, cloud resources, operational technology, and suppliers belong inside?
- What is outside but connected, inherited, relied upon, or managed through an agreement?
- Where are trust boundaries, authorization boundaries, data flows, administrative paths, and external services?
- Who owns each component and control responsibility?
- Which changes require recategorization, reselection, reassessment, or authorization review?

Boundary artifact	What it should show
System description	Purpose, users, environment, operating status, technologies, dependencies
Architecture diagram	Components, zones, interfaces, trust boundaries, management paths
Data flow	Information types, sources, destinations, processing, storage, sharing, disposal
Inventory	Hardware, software, firmware, virtual/cloud resources, owners, versions
Interconnection agreement	Systems, data, controls, responsibilities, monitoring, incident and termination
Control allocation	Common, hybrid, system-specific, inherited, provider, customer responsibilities

5. Prepare at the Organization Level

Organization-level preparation makes system RMF work consistently and efficiently.

5.1 Organization preparation

- Establish risk-management roles, strategy, risk tolerance, priorities, and communication.
- Identify missions, business processes, legal/policy/contract requirements, stakeholders, and critical assets.
- Develop enterprise architecture, security/privacy architecture, common controls, organization-wide requirements, and monitoring strategy.
- Establish impact guidance, baseline tailoring rules, parameter values, overlays, assessment expectations, and authorization approach.
- Identify supply-chain risks, external providers, organization-wide threats, assumptions, and dependencies.
- Create repositories, automation, templates, evidence standards, quality review, metrics, and improvement processes.

Efficiency principle: Reusable common controls, approved parameters, standard evidence, and machine-readable content reduce repeated system work—only when ownership and current operating evidence are reliable.

6. Prepare at the System Level

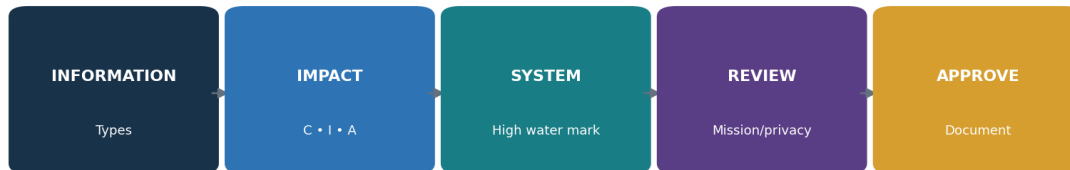
System-level preparation defines the specific mission, stakeholders, boundary, information, and approach.

6.1 System preparation

- Identify mission/business purpose, system owner, authorizing official, security/privacy officers, assessors, providers, users, and stakeholders.
- Define authorization boundary, system elements, operating environment, dependencies, interfaces, external services, and supply chain.
- Identify information types, processing purposes, privacy risks, data flows, and legal/contractual requirements.
- Determine life-cycle stage, development/acquisition approach, architecture, engineering needs, and planned authorization strategy.
- Register the system; identify common-control inheritance and organization-provided resources.
- Document assumptions, constraints, risks, required decisions, and package schedule.

7. Categorize the System

Categorization describes the potential impact of the loss of confidentiality, integrity, or availability.



Categorization expresses potential impact—not the current quality of controls

Figure 3. Categorization workflow

7.1 Method

- Identify all information types processed, stored, or transmitted.
- Assign potential impact—low, moderate, or high—for confidentiality, integrity, and availability using applicable guidance and mission context.
- Apply the high-water-mark concept for the system security category, then review whether aggregation, dependencies, privacy, safety, or mission effects justify adjustment under authority.
- Document rationale, assumptions, affected parties, and approval.
- Revisit when mission, data, architecture, environment, users, suppliers, or threats materially change.

Categorization warning: A high-impact category does not mean controls are weak, and a low-impact category does not mean the system is secure. It expresses potential harm if security objectives are lost.

8. Select Controls

Selection creates a tailored set of controls that addresses system and organizational risk.

8.1 Selection sequence

- Choose the appropriate baseline or organization-defined starting profile.
- Apply scoping considerations and identify controls that are applicable, not applicable, inherited, hybrid, or system-specific.
- Assign organization-defined parameters such as frequencies, time periods, roles, technologies, and thresholds.
- Add controls or enhancements for threat, mission, privacy, supply chain, law, policy, contract, architecture, or risk.
- Use compensating controls only through approved equivalence and documented rationale.
- Develop monitoring and assessment approaches; identify implementation responsibility and evidence.
- Document the tailored set, rationale, dependencies, common controls, and residual risk.

Control selection is not implementation: Selecting AC-2 does not create account management. The system must define and operate the people, process, technology, evidence, and monitoring needed for every selected requirement.

9. Implement Controls

Implementation turns selected controls into real, assigned, configured, and operated safeguards.

9.1 Implementation workflow

- Parse each control statement, enhancement, parameter, supplemental guidance, related controls, and allocation.
- Translate requirements into architecture, procedures, configurations, automation, training, contracts, and operating tasks.
- Assign accountable control owner and responsible implementers; identify inherited and shared portions.
- Define population, frequency, trigger, approval, exception, logging, review, metric, and evidence.
- Build and test through the system development life cycle; use configuration and change management.
- Write an accurate implementation statement that explains who does what, where, how, when, with what configuration and evidence.
- Correct design or operation gaps before formal assessment when possible.

10. Assess Controls

Assessment determines whether controls are implemented correctly, operating as intended, and producing the desired outcome.

10.1 Assessment sequence

- Identify assessor independence and qualifications appropriate to risk.
- Develop and approve an assessment plan with scope, controls, procedures, methods, objects, depth, coverage, schedule, rules, evidence, sampling, and safety.
- Validate system boundary, control set, implementation, populations, inherited controls, and source reliability.
- Use examine, interview, and test methods; inquiry alone usually provides weak evidence.
- Record satisfied or other-than-satisfied results with evidence, exceptions, limitations, and risk.
- Allow responsible officials to correct findings; retest corrections independently.
- Issue an assessment report that supports the authorizing official's decision without hiding uncertainty.

Assessment is not a scan: Automated results can test important conditions at scale, but assessment also requires criteria, scope, population, design, operating context, human review, limitations, and risk analysis.

11. Authorize the System or Common Controls

Authorization is an explicit senior risk decision based on the package and organizational context.



Authorization is an accountable risk decision, not a certificate of perfection

Figure 7. Authorization risk decision

11.1 Authorization package

- Security, privacy, and C-SCRM plans as applicable.
- Security and privacy assessment reports.
- Plan of action and milestones (POA&M).
- Executive summary and current risk assessment.
- Continuous monitoring strategy and significant change information.
- System description, categorization, boundary, architecture, dependencies, common-control inheritance, and agreements.

Possible decision	Meaning
Authorization to operate/use	Risk accepted for defined scope, conditions, and time
Common-control authorization	Risk decision for controls inherited by multiple systems
Authorization with conditions	Operation allowed only with stated limits, actions, milestones, or monitoring
Denial	Risk is not accepted; operation/use is not authorized under stated conditions
Ongoing authorization approach	Frequent current evidence supports continuing risk decisions under approved criteria

Not a certification: Authorization does not mean the system is risk-free or compliant forever. It is a documented acceptance of current residual risk by an official with authority.

12. Monitor Continuously

Monitor tracks controls, system changes, threat, findings, and risk after authorization.

12.1 Monitoring activities

- Track system, architecture, data, mission, user, supplier, ownership, location, threat, vulnerability, and legal changes.
- Assess selected controls at approved frequencies and event triggers using current evidence.
- Monitor common controls and communicate changes to inheriting systems.
- Update plans, inventories, diagrams, assessment results, risk register, and POA&M.
- Report posture and material change to system owners, risk executives, security/privacy officials, and authorizing officials.
- Correct weaknesses, retest, and determine whether significant change or increased risk requires reauthorization or changed terms.

Monitor for decisions: Collect only evidence that has an owner, purpose, quality rule, threshold, review cadence, escalation, and response. More dashboards do not automatically improve risk management.

13. Control Baselines and Tailoring

Baselines are starting points; tailoring makes them appropriate and defensible.



Tailoring creates a justified control set for the real system and risk

Figure 4. Control tailoring

Baseline	Purpose
Low	Starting security controls for low-impact federal systems
Moderate	Starting security controls for moderate-impact federal systems
High	Starting security controls for high-impact federal systems
Privacy	Privacy controls applied based on processing and privacy risk, not system impact level alone

13.1 Tailoring record

- Baseline/profile and release used.
- Control/enhancement added, removed, specialized, inherited, or compensated.
- Scoping rationale and risk basis.
- Every organization-defined parameter and source authority.
- Common/hybrid/system-specific allocation and provider.
- Compensating-control equivalence, limitation, approval, and monitoring.
- Residual risk, approver, date, and future review trigger.

14. Common, Hybrid, and System-Specific Controls

Control allocation explains who provides each control and which portion the system must implement.

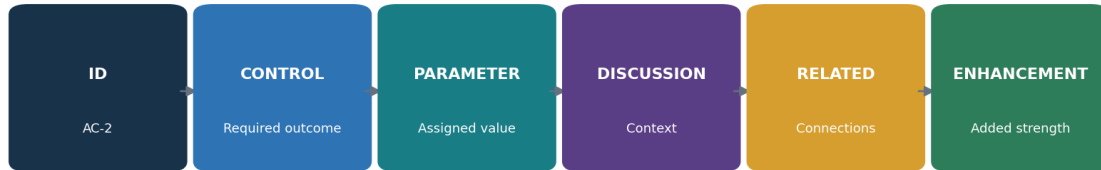
Type	Meaning	Example
Common	Implemented once for multiple systems; inherited under defined scope	Enterprise personnel screening or physical facility controls
System-specific	Implemented for one system	Application authorization rules
Hybrid	Part common and part system-specific	Enterprise identity service plus application role design
Inherited	System relies on an authorized control provider	Cloud facility/environmental protection
External service	Provider and customer responsibilities are defined by service and agreement	SaaS logging, customer SSO, provider infrastructure

14.1 Inheritance checks

- Provider, authorization status, scope, implementation, evidence, assessment, findings, changes, and expiration are known.
- The inherited control actually applies to the system's technology, location, service, and use.
- Customer/system responsibilities are implemented and tested.
- Provider changes and weaknesses are communicated to inheriting systems.
- If the common control fails or becomes unavailable, affected systems reassess risk and response.

15. Writing Strong Implementation Statements

An implementation statement must let another person understand and test the real control.



Read the full control structure before writing implementation or testing

Figure 5. Control anatomy

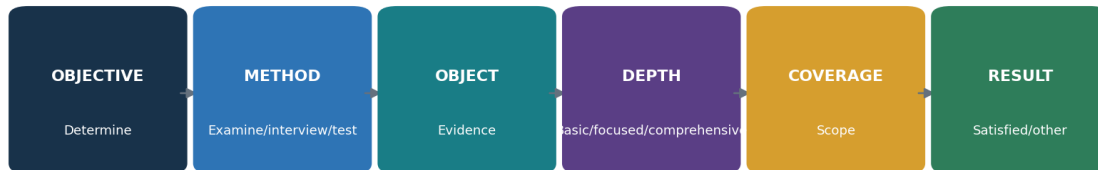
Weak statement	Stronger statement pattern
The organization uses MFA.	Identity team requires phishing-resistant MFA for named administrator roles through the approved identity service; enrollment, exceptions, and quarterly coverage review are recorded in specified systems.
Logs are reviewed.	Security operations reviews defined high-risk events continuously through the SIEM and performs documented daily review of failed administrative logons; cases and exceptions are retained for the approved period.
Backups are performed.	Operations creates encrypted daily backups of listed Tier 1 databases, maintains an isolated copy, monitors failures, and performs quarterly restore tests against four-hour RTO and 30-minute RPO.

15.1 Statement checklist

- Who owns and performs the control?
- What exact systems, accounts, data, facilities, suppliers, and population are covered?
- What process, configuration, tool, rule, and parameter implements it?
- Where does it operate and where is evidence retained?
- When/frequency/trigger and how quickly?
- How are approvals, exceptions, failures, reviews, metrics, changes, and retests handled?
- Which portion is inherited, shared, planned, not applicable, or not yet operating?

16. Assessment Planning and Evidence

SP 800-53A procedures are customized into an approved assessment plan.



Assessment procedures are tailored into a risk-based assessment plan

Figure 6. Assessment procedure structure

Element	Meaning
Assessment objective	What determination the procedure is designed to support
Method	Examine, interview, or test
Object	Specification, mechanism, activity, individual, or evidence examined
Depth	Level of rigor/detail: basic, focused, or comprehensive
Coverage	Breadth or scope: basic, focused, or comprehensive
Evidence	Reliable information supporting the determination
Result	Satisfied or other than satisfied, with exceptions and limitations

16.1 Population and sampling

- Identify the complete population before choosing a sample.
- Validate completeness and accuracy using independent sources where possible.
- Select full-population testing when automation and risk make it practical.
- For samples, document method, period, size, strata, random/judgmental basis, and limitation.
- Expand testing when exceptions suggest a pattern or population weakness.

17. Authorization Package and POA&M

The package tells the risk story from system purpose to open weakness and monitoring.

17.1 POA&M quality

- Unique finding and exact control/criteria.
- Condition, affected population, evidence, date, and source.
- Risk scenario, likelihood/impact context, severity, and dependencies.
- Cause and planned corrective action—not only a symptom.
- Milestones, resources, accountable owner, scheduled completion, and interim safeguards.
- Changes, delays, approvals, residual risk, and escalation.
- Retest procedure, evidence, result, closure reviewer, and date.

Package question	Evidence
What is being authorized?	Boundary, purpose, users, information, architecture, dependencies
What controls should apply?	Categorization, baseline, tailoring, parameters, requirements
How are controls implemented?	System/common-control plans, implementation statements, diagrams
Do controls operate?	Assessment plan/report, raw support, findings, retests
What risk remains?	Risk assessment, exceptions, POA&M, threat/change context
How will risk stay visible?	Monitoring strategy, metrics, reporting, triggers, ownership

18. Continuous Monitoring Strategy

A monitoring strategy defines what evidence is collected, how often, and what decision follows.



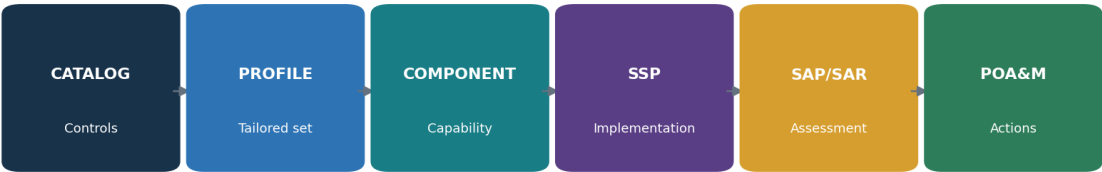
Continuous monitoring keeps the authorization basis current

Figure 8. Continuous monitoring and response

Field	Example decision content
Control/risk	What requirement and risk the evidence addresses
Indicator	Configuration, coverage, event, finding, performance, exception, or change
Source/owner	Authoritative system and accountable data owner
Frequency/trigger	Daily, monthly, annual, release, incident, provider change, significant change
Quality	Completeness, accuracy, timeliness, integrity, access, time synchronization
Threshold	Condition requiring review, escalation, correction, reassessment, or authorization action
Audience	Implementer, system owner, security/privacy official, risk executive, authorizing official
Retention	Required history, evidence protection, and package update

19. OSCAL and Automation

OSCAL supports machine-readable control, implementation, assessment, and remediation information.



OSCAL structures control, implementation, assessment, and remediation information

Figure 9. OSCAL model flow

OSCAL model	Purpose
Catalog	Structured controls, enhancements, parameters, and supporting content
Profile	Selects, modifies, and organizes controls from catalogs
Component Definition	Describes reusable control implementation capabilities
System Security Plan	Describes system and control implementation
Assessment Plan	Defines assessment scope, subjects, tasks, methods, and schedule
Assessment Results	Records observations, risks, findings, and results
Plan of Action and Milestones	Tracks risks, findings, actions, milestones, and status

19.1 Automation safeguards

- Treat official release/tag and schema as controlled dependencies.
- Validate syntax and semantics; schema-valid data can still be factually wrong.
- Use stable identifiers and trace evidence to source systems.
- Protect sensitive system, architecture, weakness, personal, and supplier information.
- Require human review for tailoring, risk, findings, exceptions, and authorization decisions.
- Track version, change, approval, transformation, inheritance, and export history.

20. Control Families: Access, Awareness, Audit, and Assessment

Four families establish who may act, how people learn, what is logged, and how assurance decisions are made.

AC — Access Control

Limit system and information access to authorized users, processes, devices, and permitted actions.

Implementation focus	Possible evidence	Analyst checks
Define scope, owner, requirements, procedures, technology, responsibilities, exceptions, and monitoring.	account inventory, roles, approvals, MFA, access rules, reviews, revocations, logs	Match evidence to the exact control; validate population, date, configuration, operation, exceptions, and retest.

AT — Awareness and Training

Build general awareness and role-specific knowledge for security and privacy responsibilities.

Implementation focus	Possible evidence	Analyst checks
Define scope, owner, requirements, procedures, technology, responsibilities, exceptions, and monitoring.	population, curriculum, role mapping, completion, exercises, exceptions, evaluation	Match evidence to the exact control; validate population, date, configuration, operation, exceptions, and retest.

AU — Audit and Accountability

Create, protect, review, retain, and use records that support detection, investigation, and accountability.

Implementation focus	Possible evidence	Analyst checks
Define scope, owner, requirements, procedures, technology, responsibilities, exceptions, and monitoring.	Event list, log sources, time sync, fields, retention, access, review, alerts	Match evidence to the exact control; validate population, date, configuration, operation, exceptions, and retest.

CA — Assessment, Authorization, and Monitoring

Assess controls, manage findings, authorize risk, and monitor security and privacy posture.

Implementation focus	Possible evidence	Analyst checks
Define scope, owner, requirements, procedures, technology, responsibilities, exceptions, and monitoring.	Assessment plans/reports, authorizations, POA&M, monitoring strategy, results	Match evidence to the exact control; validate population, date, configuration, operation, exceptions, and retest.

21. Control Families: Configuration, Contingency, Identity, Incident, and Maintenance

These families secure configuration, resilience, identity, response, and controlled maintenance.

CM — Configuration Management

Establish controlled baselines and manage secure configuration and change.

Implementation focus	Possible evidence	Analyst checks
Define scope, owner, requirements, procedures, technology, responsibilities, exceptions, and monitoring.	Baselines, inventories, approvals, change tests, scans, deviations, reviews	Match evidence to the exact control; validate population, date, configuration, operation, exceptions, and retest.

CP — Contingency Planning

Prepare, test, and maintain recovery and continuity capabilities.

Implementation focus	Possible evidence	Analyst checks
Define scope, owner, requirements, procedures, technology, responsibilities, exceptions, and monitoring.	BIA, plans, backups, alternate processing, exercises, restores, RTO/RPO	Match evidence to the exact control; validate population, date, configuration, operation, exceptions, and retest.

IA — Identification and Authentication

Uniquely identify and authenticate people, devices, and processes with risk-appropriate strength.

Implementation focus	Possible evidence	Analyst checks
Define scope, owner, requirements, procedures, technology, responsibilities, exceptions, and monitoring.	identity proofing, authenticators, MFA, federation, service identities, lifecycle logs	Match evidence to the exact control; validate population, date, configuration, operation, exceptions, and retest.

IR — Incident Response

Prepare for, detect, analyze, contain, recover from, report, and improve after incidents.

Implementation focus	Possible evidence	Analyst checks
Define scope, owner, requirements, procedures, technology, responsibilities, exceptions, and monitoring.	plan, roles, playbooks, cases, evidence, notification, exercises, lessons	Match evidence to the exact control; validate population, date, configuration, operation, exceptions, and retest.

MA — Maintenance

Control system maintenance, tools, personnel, access, and remote activity.

Implementation focus	Possible evidence	Analyst checks
----------------------	-------------------	----------------

Implementation focus	Possible evidence	Analyst checks
Define scope, owner, requirements, procedures, technology, responsibilities, exceptions, and monitoring.	maintenance schedule, approvals, tools, sanitization, remote sessions, logs	Match evidence to the exact control; validate population, date, configuration, operation, exceptions, and retest.

22. Control Families: Media, Physical, Planning, Program, and Personnel

These families protect media, facilities, plans, programs, and personnel.

MP — Media Protection

Protect, control, transport, sanitize, and dispose of digital and non-digital media.

Implementation focus	Possible evidence	Analyst checks
Define scope, owner, requirements, procedures, technology, responsibilities, exceptions, and monitoring.	media inventory, access, marking, transport, encryption, sanitization, disposal	Match evidence to the exact control; validate population, date, configuration, operation, exceptions, and retest.

PE — Physical and Environmental Protection

Protect facilities, equipment, utilities, and people from physical and environmental threats.

Implementation focus	Possible evidence	Analyst checks
Define scope, owner, requirements, procedures, technology, responsibilities, exceptions, and monitoring.	badges, visitors, cameras, alarms, power, fire, temperature, facility reviews	Match evidence to the exact control; validate population, date, configuration, operation, exceptions, and retest.

PL — Planning

Document system security and privacy plans, rules of behavior, architecture, and intended controls.

Implementation focus	Possible evidence	Analyst checks
Define scope, owner, requirements, procedures, technology, responsibilities, exceptions, and monitoring.	System plans, boundary, data flows, rules, approvals, versions, review	Match evidence to the exact control; validate population, date, configuration, operation, exceptions, and retest.

PM — Program Management

Operate organization-wide information security and privacy programs and shared governance.

Implementation focus	Possible evidence	Analyst checks
Define scope, owner, requirements, procedures, technology, responsibilities, exceptions, and monitoring.	program plans, leaders, resources, risk strategy, metrics, enterprise inventories	Match evidence to the exact control; validate population, date, configuration, operation, exceptions, and retest.

PS — Personnel Security

Manage personnel screening, agreements, transfers, termination, sanctions, and risk.

Implementation focus	Possible evidence	Analyst checks
----------------------	-------------------	----------------

Implementation focus	Possible evidence	Analyst checks
Define scope, owner, requirements, procedures, technology, responsibilities, exceptions, and monitoring.	screening, agreements, role changes, access termination, third-party personnel	Match evidence to the exact control; validate population, date, configuration, operation, exceptions, and retest.

23. Control Families: Privacy, Risk, Acquisition, Communications, Integrity, and Supply Chain

These families cover PII, risk, acquisition, architecture/communications, integrity, and supply chains.

PT — PII Processing and Transparency

Manage processing purposes, authority, minimization, consent, notice, access, correction, and privacy accountability.

Implementation focus	Possible evidence	Analyst checks
Define scope, owner, requirements, procedures, technology, responsibilities, exceptions, and monitoring.	Data inventory, purpose/authority, notices, consent, minimization, rights, assessments	Match evidence to the exact control; validate population, date, configuration, operation, exceptions, and retest.

RA — Risk Assessment

Identify threats, vulnerabilities, likelihoods, impacts, privacy issues, and risk responses.

Implementation focus	Possible evidence	Analyst checks
Define scope, owner, requirements, procedures, technology, responsibilities, exceptions, and monitoring.	Risk assessments, vulnerability results, threat sources, impact, treatment, updates	Match evidence to the exact control; validate population, date, configuration, operation, exceptions, and retest.

SA — System and Services Acquisition

Build security and privacy into acquisition, development, engineering, supply, and external services.

Implementation focus	Possible evidence	Analyst checks
Define scope, owner, requirements, procedures, technology, responsibilities, exceptions, and monitoring.	requirements, contracts, SDLC, architecture, developers, testing, SBOM, supplier evidence	Match evidence to the exact control; validate population, date, configuration, operation, exceptions, and retest.

SC — System and Communications Protection

Protect boundaries, communications, architecture, cryptography, isolation, and shared resources.

Implementation focus	Possible evidence	Analyst checks
Define scope, owner, requirements, procedures, technology, responsibilities, exceptions, and monitoring.	diagrams, segmentation, firewall rules, encryption, keys, protocols, boundary tests	Match evidence to the exact control; validate population, date, configuration, operation, exceptions, and retest.

SI — System and Information Integrity

Find and correct flaws, malicious code, integrity failures, unsafe updates, and anomalous behavior.

Implementation focus	Possible evidence	Analyst checks
Define scope, owner, requirements, procedures, technology, responsibilities, exceptions, and monitoring.	vulnerabilities, patches, integrity validation, malware defenses, alerts, corrections	Match evidence to the exact control; validate population, date, configuration, operation, exceptions, and retest.

SR — Supply Chain Risk Management

Manage risks from products, services, suppliers, developers, integrators, and supply-chain tiers.

Implementation focus	Possible evidence	Analyst checks
Define scope, owner, requirements, procedures, technology, responsibilities, exceptions, and monitoring.	C-SCRM plan, supplier inventory, criticality, contracts, provenance, monitoring, exit	Match evidence to the exact control; validate population, date, configuration, operation, exceptions, and retest.

24. Privacy Risk and Security–Privacy Collaboration

Rev. 5 integrates security and privacy controls while preserving distinct objectives and risk methods.

24.1 Collaboration

- Security manages risks from loss of confidentiality, integrity, and availability to operations, assets, individuals, other organizations, and the Nation.
- Privacy risk management examines problems individuals may experience from data processing, even when security controls work as designed.
- Joint controls need clear security/privacy ownership, shared implementation, evidence, assessment, findings, and risk communication.
- PT controls address PII processing and transparency; relevant controls across every family can also support privacy.
- Privacy baseline selection and tailoring depend on processing, purpose, authority, people, data, context, and privacy risk—not only FIPS impact.

Question	Example artifact
Why is data processed?	Purpose, authority, system/privacy plan
What data and people?	Data inventory, information types, data flow
What problems could processing create?	Privacy risk assessment / PIA as applicable
How is processing limited and explained?	Minimization, notice, consent, retention, sharing, rights procedures
How are security and privacy controls coordinated?	Collaboration index, allocations, joint evidence and findings

25. Software Updates, Patch Reliability, and Release 5.2.0

Release 5.2.0 strengthens software update, patch, integrity, and resilient-development coverage.

Release 5.2.0 change	Plain meaning
SA-15(13) — development process, standards, and tools enhancement	Adds attention to resilient software development practices related to updates and patches
SA-24 — Design for Cyber Resiliency	New control emphasizing system/software design that can withstand, recover, adapt, and continue under adverse conditions
SI-02(07) — flaw remediation enhancement	Adds requirements focused on reliable and secure software/firmware updates
SI-07(12) — integrity verification enhancement revision	Revises existing integrity-related requirements
Discussion / related-control updates	Clarifies acquisition, design, documentation, update management, integrity, monitoring, incident, and assessment relationships
SP 800-53A 5.2.0	Adds corresponding procedures for the new controls/enhancements
SP 800-53B 5.2.0	Reissued for consistency; NIST states baseline selections did not change

25.1 Evidence focus

- Update origin, signing, integrity verification, protected delivery, approval, testing, rollback, failure handling, inventory, deployment coverage, monitoring, and records.
- Developer and supplier practices, build/release access, provenance, SBOM, vulnerability response, support period, end-of-life, and customer communication.
- Resilient design assumptions, adverse-condition behavior, isolation, degradation, recovery, diversity, redundancy, and exercise results.

26. Open-Source Tools and Official Resources

Official resources and open-source tools can support authoring, evidence, assessment, and continuous monitoring.

Resource / tool	Purpose
NIST CPRT	Official current controls, baselines, procedures, and downloads
NIST OSCAL Content	Official machine-readable NIST control content
Compliance Trestle	OSCAL authoring, transformation, and governance
Lula	Evaluate control evidence as code
CISO Assistant	Risk, controls, evidence, assessments, and findings
Heimdall	View and normalize security assessment results
OpenControl	Compliance documentation as structured text
OSCAL CLI	Validate and transform OSCAL content
Wazuh	Endpoint monitoring, file integrity, log analysis, and alerts
OpenSCAP	Configuration and vulnerability assessment
osquery	Endpoint inventory and configuration queries
Nmap	Authorized asset and service discovery
Greenbone Community Edition	Authorized vulnerability assessment
Trivy	Repository, image, dependency, secret, and IaC checks
OWASP ZAP	Authorized web application security testing
Keycloak	Identity, roles, MFA, sessions, and audit events
DefectDojo	Finding aggregation, assignment, remediation, and retest
Open Policy Agent	Policy-as-code decisions

Authorization and limits: Use technical tools only on systems, networks, repositories, data, and accounts you own or have written permission to test. A tool can support evidence; it cannot choose risk tolerance, approve tailoring, accept risk, or issue authorization.

26.1 NIST CPRT

Purpose: Official current controls, baselines, procedures, and downloads. Official project: [NIST CPRT](#)

Safe quick start: Open the catalog, select SP 800-53 Release 5.2.0, review the exact control and discussion, then export an approved format and record release/date.

Retain: authority, scope, source/release, version, configuration/query, population, date, raw result, analyst validation, limitation, control mapping, finding, correction, and retest. Protect system and vulnerability information.

26.2 NIST OSCAL Content

Purpose: Official machine-readable NIST control content. Official project: [NIST OSCAL Content](#)

Safe quick start: Clone or download a tagged release, validate file identity, inspect the SP 800-53 catalog/profile, and preserve the source version.

Retain: authority, scope, source/release, version, configuration/query, population, date, raw result, analyst validation, limitation, control mapping, finding, correction, and retest. Protect system and vulnerability information.

26.3 Compliance Trestle

Purpose: OSCAL authoring, transformation, and governance. Official project: [Compliance Trestle](#)

Safe quick start: Create a lab workspace, import official OSCAL, author a small profile and component definition, validate, review changes, and export.

Retain: authority, scope, source/release, version, configuration/query, population, date, raw result, analyst validation, limitation, control mapping, finding, correction, and retest. Protect system and vulnerability information.

26.4 Lula

Purpose: Evaluate control evidence as code. Official project: [Lula](#)

Safe quick start: Use a lab repository, define one non-destructive validation mapped to a control, run it against synthetic or authorized data, review evidence, and version the result.

Retain: authority, scope, source/release, version, configuration/query, population, date, raw result, analyst validation, limitation, control mapping, finding, correction, and retest. Protect system and vulnerability information.

26.5 CISO Assistant

Purpose: Risk, controls, evidence, assessments, and findings. Official project: [CISO Assistant](#)

Safe quick start: Create a scoped project, load a relevant framework, assign owners, document implementation, attach evidence, assess, and track findings.

Retain: authority, scope, source/release, version, configuration/query, population, date, raw result, analyst validation, limitation, control mapping, finding, correction, and retest. Protect system and vulnerability information.

26.6 Heimdall

Purpose: View and normalize security assessment results. Official project: [Heimdall](#)

Safe quick start: Import an approved sample result, confirm mappings and scoring, review exceptions, restrict access, and export a sanitized report.

Retain: authority, scope, source/release, version, configuration/query, population, date, raw result, analyst validation, limitation, control mapping, finding, correction, and retest. Protect system and vulnerability information.

26.7 OpenControl

Purpose: Compliance documentation as structured text. Official project: [OpenControl](#)

Safe quick start: Create a lab component, map one control, write implementation details and evidence references, peer-review, and track in version control.

Retain: authority, scope, source/release, version, configuration/query, population, date, raw result, analyst validation, limitation, control mapping, finding, correction, and retest. Protect system and vulnerability information.

26.8 OSCAL CLI

Purpose: Validate and transform OSCAL content. Official project: [OSCAL CLI](#)

Safe quick start: Validate a small lab OSCAL file, correct schema errors, transform only with approved versions, and retain validation output.

Retain: authority, scope, source/release, version, configuration/query, population, date, raw result, analyst validation, limitation, control mapping, finding, correction, and retest. Protect system and vulnerability information.

26.9 Wazuh

Purpose: Endpoint monitoring, file integrity, log analysis, and alerts. Official project: [Wazuh](#)

Safe quick start: Enroll a lab endpoint, generate a harmless event, validate collection and alerting, document coverage and limitations, and retain evidence.

Retain: authority, scope, source/release, version, configuration/query, population, date, raw result, analyst validation, limitation, control mapping, finding, correction, and retest. Protect system and vulnerability information.

26.10 OpenSCAP

Purpose: Configuration and vulnerability assessment. Official project: [OpenSCAP](#)

Safe quick start: Choose an applicable profile for a lab system, run an authorized scan, validate results, document tailoring, remediate, and rescan.

Retain: authority, scope, source/release, version, configuration/query, population, date, raw result, analyst validation, limitation, control mapping, finding, correction, and retest. Protect system and vulnerability information.

26.11 osquery

Purpose: Endpoint inventory and configuration queries. Official project: [osquery](#)

Safe quick start: Run read-only lab queries, define the population, compare results to requirements, validate exceptions, and record query/version.

Retain: authority, scope, source/release, version, configuration/query, population, date, raw result, analyst validation, limitation, control mapping, finding, correction, and retest. Protect system and vulnerability information.

26.12 Nmap

Purpose: Authorized asset and service discovery. Official project: [Nmap](#)

Safe quick start: Scan only written-authorized ranges with limited options, reconcile to inventory, investigate unknowns, and preserve scope and command evidence.

Retain: authority, scope, source/release, version, configuration/query, population, date, raw result, analyst validation, limitation, control mapping, finding, correction, and retest. Protect system and vulnerability information.

26.13 Greenbone Community Edition

Purpose: Authorized vulnerability assessment. Official project: [Greenbone Community Edition](#)

Safe quick start: Update feeds, define approved targets and credentials, validate coverage, review findings, correct, and rescan.

Retain: authority, scope, source/release, version, configuration/query, population, date, raw result, analyst validation, limitation, control mapping, finding, correction, and retest. Protect system and vulnerability information.

26.14 Trivy

Purpose: Repository, image, dependency, secret, and IaC checks. Official project: [Trivy](#)

Safe quick start: Scan an authorized training repository or image, validate findings, correct or document approved exceptions, and rescan in CI.

Retain: authority, scope, source/release, version, configuration/query, population, date, raw result, analyst validation, limitation, control mapping, finding, correction, and retest. Protect system and vulnerability information.

26.15 OWASP ZAP

Purpose: Authorized web application security testing. Official project: [OWASP ZAP](#)

Safe quick start: Use a training application, crawl passively, use active scanning only with permission, validate findings, fix, and retest.

Retain: authority, scope, source/release, version, configuration/query, population, date, raw result, analyst validation, limitation, control mapping, finding, correction, and retest. Protect system and vulnerability information.

26.16 Keycloak

Purpose: Identity, roles, MFA, sessions, and audit events. Official project: [Keycloak](#)

Safe quick start: Create a lab realm, configure roles and MFA, test joiner-mover-leaver and privileged cases, and review events.

Retain: authority, scope, source/release, version, configuration/query, population, date, raw result, analyst validation, limitation, control mapping, finding, correction, and retest. Protect system and vulnerability information.

26.17 DefectDojo

Purpose: Finding aggregation, assignment, remediation, and retest. Official project: [DefectDojo](#)

Safe quick start: Import safe lab findings, validate deduplication and severity, assign action, attach evidence, and close only after retest.

Retain: authority, scope, source/release, version, configuration/query, population, date, raw result, analyst validation, limitation, control mapping, finding, correction, and retest. Protect system and vulnerability information.

26.18 Open Policy Agent

Purpose: Policy-as-code decisions. Official project: [Open Policy Agent](#)

Safe quick start: Write a small lab policy for an approved configuration rule, test allow/deny and failure cases, peer-review, log decisions, and preserve human exception authority.

Retain: authority, scope, source/release, version, configuration/query, population, date, raw result, analyst validation, limitation, control mapping, finding, correction, and retest. Protect system and vulnerability information.

27. Manager's RMF Playbook

Managers keep RMF focused on mission risk, reliable evidence, timely decisions, and correction.

Area	Manager question	Red flag
Boundary	Do we know what is inside, inherited, connected, and externally provided?	Unknown cloud, supplier, or admin path
Categorization	Does impact reflect every information type, dependency, privacy, safety, and mission effect?	Category copied from another system
Selection	Are baseline, tailoring, parameters, additions, and allocations justified?	Control set treated as untailed checklist
Implementation	Can owners explain who/what/where/how/when and show operating evidence?	Policy language copied as implementation
Assessment	Are scope, population, methods, independence, limitations, and retests credible?	Scan equals assessment
Authorization	Does the decision official understand residual risk and conditions?	Package hides severe/open uncertainty
Monitoring	Do changes and indicators lead to response and package updates?	Dashboard without accountable action
POA&M	Are severe and overdue actions funded and independently retested?	Repeated extensions without risk decision

27.1 Manager rhythm

- Monthly: severe findings, significant changes, overdue POA&Ms, common-control changes, monitoring thresholds, and authorization conditions.
- Quarterly: control evidence quality, vulnerability and configuration trends, supplier risks, privacy risks, recovery/incident results, and resource blockers.
- At releases or major changes: boundary, categorization, control set, assessment, and authorization impact.
- Annually or approved cycle: risk strategy, common controls, parameter values, monitoring strategy, assessor capability, package quality, metrics, and process improvement.

28. Junior Analyst Career Guide

Junior RMF analysts create value through accurate boundaries, mappings, statements, evidence, findings, and tracking.



Junior analysts build credibility through traceable, accurate work

Figure 10. Junior RMF analyst pathway

• 28.1 Common roles

- Junior GRC Analyst
- RMF Analyst
- Security Controls Assessor (junior)
- Information System Security Officer support
- Cybersecurity Compliance Analyst
- Security Authorization Analyst
- Privacy Controls Analyst
- Continuous Monitoring Analyst

28.2 Typical work

- Maintain system inventory, boundary, information types, categorizations, control allocation, evidence, findings, POA&M, and package versions.
- Read exact control text and procedures; record release and organization-defined parameters.
- Draft implementation statements and validate them with owners and evidence.
- Gather evidence securely, validate population and source quality, perform approved examine/interview/test steps, and document limitations.
- Write clear findings and track milestones through independent retest.

- Use CPRT, OSCAL, spreadsheets, repositories, dashboards, and approved technical tools without claiming authority beyond the role.

29. Fictional Laboratory, Thirty-Day Plan, and Interview Preparation

A fictional system and authorized lab can become a strong entry-level portfolio.

Lab rule: Use fictional organizations, synthetic data, isolated systems, and written authorization. Never scan public targets or publish real system plans, vulnerabilities, credentials, diagrams, or assessment evidence.

29.1 Portfolio lab

- Create a fictional 100-person organization and a cloud-hosted customer portal with an identity provider, database, CI/CD pipeline, support supplier, and personal data.
- Define mission, stakeholders, boundary, inventory, architecture, data flow, dependencies, external services, and control allocation.
- Categorize confidentiality, integrity, and availability with documented information types and impact rationale.
- Select a moderate baseline as an educational starting point; tailor 20 representative controls and parameters with fictional risk rationale.
- Write ten strong implementation statements across different families.
- Create an assessment plan and test five controls using synthetic evidence and authorized lab tools.
- Write two findings, a POA&M, correction evidence, and retest results.
- Create a short authorization briefing and continuous monitoring strategy.
- Represent one profile, SSP fragment, assessment result, or POA&M in OSCAL and validate it.
- Publish sanitized artifacts clearly labeled fictional and not a NIST authorization.

29.2 Thirty-day plan

Days	Focus	Deliverable
1–4	RMF, publication suite, roles, three levels	Concept map and RACI
5–7	Boundary, information, data flow, categorization	System description and category memo
8–11	Baselines, tailoring, parameters, allocation	Tailored representative control set
12–15	Implementation and family study	Ten implementation statements
16–19	SP 800-53A methods, populations, sampling	Assessment plan and five workpapers
20–22	Findings, risk, POA&M, retest	Two finding-to-closure records
23–25	Authorization and monitoring	Executive brief and monitoring strategy
26–27	OSCAL and approved tools	Validated OSCAL fragment and tool evidence
28–30	Portfolio and interview	Sanitized portfolio and five STAR stories

29.3 What is RMF?

A seven-step life-cycle process for managing security and privacy risk: Prepare, Categorize, Select, Implement, Assess, Authorize, and Monitor.

29.4 Is SP 800-53 a checklist?

No. It is a flexible control catalog. Organizations choose and tailor controls through risk management and applicable requirements.

29.5 What is a baseline?

A starting set of controls. SP 800-53B provides low, moderate, high, and privacy baselines for federal use.

29.6 What is tailoring?

Documented scoping, parameters, additions, specialization, allocation, and approved compensating controls that make the starting set fit the system and risk.

29.7 What is control inheritance?

A system relies on a control provided by another authorized provider, while still implementing and testing its own customer responsibilities.

29.8 How do you assess a control?

Use approved objectives and examine, interview, or test methods with defined objects, depth, coverage, population, evidence, exceptions, and limitations.

29.9 What is authorization?

An authorized senior official's decision to accept defined residual risk for a system or common controls under stated terms.

29.10 What is a POA&M?

A tracked plan for correcting identified weaknesses, with risk, owner, milestones, resources, schedule, status, and retest.

29.11 What is OSCAL?

NIST's machine-readable models for controls, profiles, implementations, assessments, results, and POA&Ms.

29.12 What is current SP 800-53?

Revision 5, Release 5.2.0, issued in August 2025.

30. Templates, Glossary, Index, and References

Reusable work structures, key terms, subject index, and official sources.

30.1 System and boundary record

Field	Entry
System/owner/mission	_____
Authorization boundary	_____
Information types/data flow	_____
Architecture/interfaces	_____
External services/suppliers	_____
Common controls/inheritance	_____
Dependencies/locations	_____
Category/rationale	_____
Life-cycle stage/changes	_____
Approvals/version	_____

30.2 Control implementation workpaper

Field	Entry
Control/enhancement/release	_____
Parameter/requirement	_____
Allocation/provider	_____
Scope/population	_____
Who / what / where	_____
How / configuration	_____
When / trigger/frequency	_____
Evidence/source/retention	_____
Exception/failure/review	_____
Owner/approval/update	_____

30.3 Assessment and finding record

Field	Entry
Objective/method/object	_____
Depth/coverage/period	_____
Population/sample/reliability	_____
Steps/tools/version	_____
Evidence/result	_____
Exception / affected population	_____
Risk/cause	_____
Action/owner/milestones	_____
Interim protection	_____
Retest/closure	_____

30.4 Authorization and monitoring record

Field	Entry
Package/version/date	_____
Residual risk summary	_____
Decision/official/terms	_____

Field	Entry
Conditions/expiration	
POA&M / severe risks	
Indicators/source/frequency	
Threshold/escalation	
Significant-change triggers	
Reporting/package update	
Reauthorization/closure	

30.5 Glossary

Term	Meaning
Authorization	Official acceptance of defined residual risk for a system or common controls.
Authorization boundary	Set of system elements included in the risk decision.
Baseline	Starting control set.
Common control	Control implemented for multiple systems.
Control enhancement	Additional or stronger requirement associated with a base control.
Control inheritance	Reliance on an applicable control implemented by another provider.
Control parameter	Organization-assigned value inside a control.
CPRT	NIST Cybersecurity and Privacy Reference Tool.
High-water mark	System impact takes precedence over other applicable information/security objectives, subject to approved analysis.
OSCAL	Open Security Controls Assessment Language.
POA&M	Plan of action and milestones for weaknesses, with corrective actions.
Residual risk	Risk remaining after controls and treatment.
RMF	Risk Management Framework.
Security categorization	Potential-impact determination for confidentiality, integrity, and availability.
System Security Plan	Description of system and control implementation.
Tailoring	Risk-based adjustment and specification of a starting control set.

30.6 Subject index

Subject	Chapter
Assessment	10, 16–17
Authorization	11, 17
Baselines/tailoring	13
Categorization	7
Common controls	14
Control families	20–23
Implementation	9, 15
Junior analyst	28–29
Manager	27
Monitoring	12, 18
OSCAL	19, 26
POA&M	17, 30
Privacy	24
Release 5.2.0	2, 25
Roles	3
Selection	8
System boundary	4
Tools	26

30.7 Official references

- [NIST Risk Management Framework](#)

- [NIST SP 800-37 Rev. 2](#)
- [NIST SP 800-53 Rev. 5 and Release 5.2.0](#)
- [NIST SP 800-53A Rev. 5 and Release 5.2.0](#)
- [NIST SP 800-53B](#)
- [NIST 2025 Release 5.2.0 announcement](#)
- [NIST SP 800-18 Rev. 2](#)
- [NIST SP 800-30 Rev. 1](#)
- [NIST SP 800-39](#)
- [NIST CPRT](#)
- [NIST OSCAL](#)
- [NIST SP 800-53 controls downloads](#)
- [NIST RMF introductory courses](#)

Final reminder: NIST releases, baselines, parameters, overlays, systems, threats, laws, contracts, tools, and organizational risk change. Confirm the current official source, local authority, and applicable requirements before implementation, assessment, or authorization.